

MID-STATE TECHNICAL COLLEGE • IT PROGRAMS

Network Scanning

Unit 3 • Ethical Hacking (10-151-160)



Learning Outcomes

By the end of this unit, you will be able to:



Navigate Linux from the terminal

Move through the filesystem, escalate with sudo, and read permission bits on a Kali system.



Extract intelligence from file metadata

Pull EXIF from an image, geolocate it, and explain what strips it and what quietly does not.



Explain how port scans work

Describe the TCP handshake, contrast full-connect with half-open, and account for UDP ambiguity.



Scan authorized targets and read the output

Run Nmap, Nikto, Legion, and Masscan with flags you can justify, and interpret what comes back.



Detect scanning and handle findings responsibly

Identify the evidence a scan leaves, propose proportionate controls, and classify results with TLP.

Rules of Engagement

Authorization is the only thing separating this coursework from a felony:

- In scope for this unit: **www.mstclab.com**, a **Hack The Box** or **TryHackMe** machine you have joined, and hosts you personally own.
- Everything else is out of scope, including the college network, your employer, and "just the front page" of a site you like.
- Scanning without authorization violates the **Computer Fraud and Abuse Act** and **Wis. Stat. §943.70** — regardless of intent, and regardless of whether anything breaks.
- If you are not certain a target is in scope, ask before you scan. There is no partial credit for a good guess.



SECURITY FOCUS

Online scanners run from the provider's address, not yours — but you have still handed a third party the name of your target.

Why it matters: Under a client confidentiality agreement, that disclosure alone can breach the contract.

LESSON 1

Linux Foundations



Orienting Yourself in the Terminal

Every tool in this unit is driven from a shell. Start by answering where and who:

- `pwd` — print working directory. Where am I?
- `whoami` — which user am I right now? Changes after `su` or inside a shell you caught.
- `sudo` — super user do. `sudo !!` re-runs the command you just forgot to elevate.
- `cd /etc`, `cd ..`, `cd -` — absolute, up one, and back to where you were.
- Up arrow and `history | grep nmap` recover the scan you ran an hour ago.

Case sensitivity is absolute

`/etc/passwd` and `/etc/Passwd` are two different paths, and only one of them exists.

This applies to commands, filenames, and arguments alike. Use tab completion and stop typing paths by hand.

LIVE DEMO

Open a Kali shell; run `pwd`, `whoami`, then `sudo whoami`.

The Filesystem Hierarchy

Everything hangs off the root directory. These are the ones worth memorizing:

Path	What lives there	Why an attacker cares
/etc	Configuration files and service startup	Credentials, hosts, service config
/home /root	User and root home directories	Keys, history files, saved sessions
/var/log	System and service logs	Evidence of your scan lands here
/tmp	World-writable scratch space	Classic staging directory for tooling
/usr/share	Tool data and wordlists	Kali keeps NSE scripts and lists here

/bin and /sbin hold binaries; /lib holds shared libraries — the rough equivalents of Windows executables and DLLs.

Permissions and Why Scans Need Root

Ten characters: a type indicator, then read/write/execute for user, group, and other.

```
-rwxr-xr-- 1 kali kali 4096 Sep 8 09:15 scan.sh
```

- **r = 4, w = 2, x = 1** — add per triad for the octal form, so the line above is 754.
- `chmod` changes the bits; `chown user:group file` changes ownership and almost always needs `sudo`.
- The **SUID bit** (`chmod u+s`) runs a binary as its owner rather than its caller — a classic privilege-escalation path.



Raw sockets need root

Half-open and UDP scans build their own packets, which needs `CAP_NET_RAW`.

Unprivileged Nmap falls back to a slower connect scan **without telling you**.

LESSON 2

Dorking and Metadata



The Google Hacking Database

A curated, searchable archive of pre-built Google dorks — an extension of last unit's operators.

- **Files containing juicy info** — configuration files, backups, and credentials indexed by mistake.
- **Pages containing login portals** — admin interfaces that were never meant to be publicly reachable.
- **Various online devices** — printers, cameras, and controllers with default web front ends.
- **Error messages** — stack traces that leak versions, file paths, and database schema.



Still passive

Google did the crawling, not you. Nothing on this slide sends a packet to the target.

That makes dorking a cheap first move before anything else in this unit.

LIVE DEMO

Search the GHDB for a category, then run one dork against a domain you own.

Metadata: What a Photograph Gives Away

The same photograph, twice. One straight from the camera, one copied and given a new extension.



Original · straight from the camera



Copied and renamed · still carries every tag



Both return the same GPS block

Copying a file does not sanitize it, and changing the extension changes nothing about the bytes inside.

Around 11 KB of EXIF survives in each — camera, timestamps, and a satellite fix.

LIVE DEMO

Right-click → Properties → Details on both files before showing exiftool.

Reading the Tags

```
$ exiftool -gpslatitude -gpslongitude -make -model -datetimeoriginal photo.jpg
GPS Latitude      : 43 deg 28' 2.81" N      Camera Model : COOLPIX P6000
GPS Longitude     : 11 deg 53' 6.46" E      Make          : NIKON
Date/Time Original : 2008:10:22 16:28:39
```

- **Convert to decimal** — degrees + minutes/60 + seconds/3600 gives 43.46745, 11.88513.
- **Make and Model** narrow the device; serial numbers sometimes hide in the MakerNote.
- **DateTimeOriginal** is when the shutter fired — distinct from file modification time and much harder to fake.
- **Strip it with** `exiftool -all= image.jpg`, then verify by re-reading the file rather than trusting the command.

Why Metadata Matters

Aggregated metadata is a surveillance capability, not a curiosity:

- The tool **Creepy** builds a geolocation timeline of an individual from their public images alone.
- The project **The Follower** matched posted photographs against archived open-camera footage to find video of the person taking the picture.
- On an engagement, company images leak facility layouts, badge designs, screen contents, and installed software.
- Documents count too — Office files and PDFs carry authors, usernames, internal paths, and printer names.



SECURITY FOCUS

Most large social platforms strip EXIF on upload. Chat apps, file shares, email attachments, and CMS uploads frequently do not.

Why it matters: The only reliable control is disabling geotagging at the source — never writing the coordinates at all.

LESSON 3

How Scanning Works



What Is Scanning?

Automated enumeration of an environment — using a tool to map a landscape faster than you could by hand.

Type	What it answers	Typical tool
Network	Which hosts are up, which ports listen	Nmap, Masscan
Vulnerability	Do these services match known flaws?	Nessus, OpenVAS
Application	Is this web app misconfigured?	Nikto, Burp
Code	Are there flaws before deployment?	Semgrep, Snyk
Cloud / config	Public buckets, drift from a baseline?	ScoutSuite, CIS-CAT

This unit covers network scanning only. Many tools blur these lines — knowing which job you are doing is your responsibility, not the tool's.

Why We Scan

If you take one thing from this course, take this:

Know your network. You cannot defend, and you cannot honestly assess, an environment you have not enumerated.

- **See the attack surface** — every listening port is a door, including the ones nobody remembers installing.
- **Find the obvious flaws** — default credentials, forgotten test servers, deprecated protocols.
- **Identify what needs watching** — a business that genuinely requires RDP open is not a finding you can close, so it becomes a monitoring requirement.
- **Establish a baseline** — a scan you can compare against next month turns a snapshot into change detection.
- **Verify remediation** — re-scanning is how you prove the fix landed instead of taking someone's word for it.

It All Starts with the Handshake

Almost everything in TCP scanning follows from three packets:

```
OPEN      you --SYN--> target      target --SYN/ACK--> you      you --ACK--> target
CLOSED    you --SYN--> target      target --RST-----> you
FILTERED  you --SYN--> target      (nothing comes back — a firewall dropped it silently)
```

- An **open** port completes the handshake. A **closed** port answers with RST, which still proves the host is alive.
- A **filtered** port usually answers with nothing at all — silence is a firewall, not an absence.
- Every scan type you will use is a decision about how much of this exchange to finish.

Full Connect vs. Half-Open

Full Connect — -sT

- Completes the entire three-way handshake using the OS `connect()` call
- No special privileges needed; results are unambiguous
- Noisy — the target application logs a real session, not just the firewall
- Slower: every port costs a full setup and teardown

Half-Open (SYN) — -sS

- Sends SYN, reads the SYN/ACK, then sends RST to tear down
- Faster, and often never reaches the application log
- Requires raw sockets, so it needs `sudo`. Default when running as root
- Leaves half-open connections behind — the same mechanism as a SYN-flood DoS

"Stealth" is a marketing word: A half-open scan is invisible to the application log and completely obvious in NetFlow. Assume a competent defender sees it.

UDP and Signature-Based Scanning

Not everything is TCP, and not every scan is looking for open ports:

- **UDP is connectionless** — no handshake to observe. ICMP type 3 code 3 means closed; other unreachable codes mean filtered; a UDP reply proves open.
- **Silence means open|filtered** — genuinely unknown. The scanner must retransmit and wait out timeouts on every quiet port.
- **Do not skip it anyway** — DNS (53), SNMP (161), TFTP (69), NTP (123), and IKE (500) are all UDP and all regularly abused.
- **Vulnerability scanning is signature-driven** — identify the service and version, then look it up. Blind to anything not in the signature set.



SECURITY FOCUS

A signature match on a version string is a hypothesis, not a finding. Enterprise Linux backports security patches without changing the version number.

Why it matters: Report an unverified "critical" and you spend your credibility on a patch that shipped months ago.

Reading Port States

Nmap reports six states. The difference between them is the difference between a useful report and a misleading one.

State	What it means	What you do about it
open	An application is accepting connections	Fingerprint it with -sV
closed	Host answered; nothing is listening	Proves the host is alive
filtered	Probe was dropped by a firewall or ACL	Map the boundary it reveals
unfiltered	Reachable, state undetermined (ACK scan)	Follow up with -sS
open filtered	No response at all — common on UDP	Re-probe with -sV
closed filtered	Cannot distinguish the two (idle scan)	Rarely actionable

A wall of "filtered" is itself a finding: it tells you the firewall works, and it tells the defender exactly where your traffic is.

LESSON 4

The Toolkit



Building Your Environment

Kali ships with nearly everything in this unit already installed. Two supported paths:

Virtual machine — recommended

- VMware Workstation Pro, free for personal use
- Download the prebuilt Kali image rather than installing
- Default login `kali / kali` — change it
- Know your network mode: NAT and bridged put you on the real network

WSL — convenient for quick work

- `wsl --install --distribution kali-linux`
- Fine for text tooling and quick lookups
- Raw packet and wireless operations behave differently — prefer the VM

```
sudo apt update && sudo apt upgrade -y && sudo apt install kali-linux-default
```

LIVE DEMO

Boot the VM, log in, update, then take a clean snapshot before anyone experiments.

Anatomy of an Nmap Command

Nmap commands follow one shape — scan type, options, target:

```
$ sudo nmap -sS -sV -p- -T4 -oA mstclab www.mstclab.com
|      |      |      |      |
|      |      |      |      +-- save all output formats to mstclab.*
|      |      |      +----- timing template (0 paranoid .. 5 insane)
|      |      +----- all 65,535 TCP ports, not just the top 1000
|      +----- service and version detection
+----- half-open SYN scan
```

Bare nmap target runs host discovery, then a SYN scan of the top 1,000 ports if you are root and a connect scan if you are not. Everything beyond that default is a choice you must be able to defend.

Nmap Flags That Matter

Flag	What it does	When to reach for it
-sn	Ping sweep only, no port scan	First move against a subnet
-Pn	Skip discovery, treat all hosts as up	When ICMP is blocked
-p- / -F	All 65,535 ports / top 100 only	Thorough vs. fast triage
-sV	Service and version detection	Turning a port into a finding
-sC	Run the default NSE script set	Cheap extra context
-A	OS + version + scripts + traceroute	Only where noise does not matter
-oA	Write all output formats at once	Always. Save every scan

--script vuln is loud and can crash fragile services. Never point it anywhere without written authorization.

Reading the Results

Read the ports table in this order — the questions matter more than the output:

- **Is the host up, and how did Nmap decide?** Up because one closed port sent a RST is a different situation from an ICMP reply.
- **What is open, and does it belong there?** A port nobody can account for is the most valuable line in the report.
- **What does SERVICE actually mean?** Without `-sV` it is a lookup in `/etc/services` — a guess, not evidence.
- **Is anything conspicuously old?** Version strings are where a network scan becomes a vulnerability finding.
- **What is missing?** A web server with no reachable SSH is still managed somehow — find the jump host.

Common Ports: Start Memorizing

Recognizing a service on sight is what lets you read a scan result in seconds instead of thirty lookups.

Port	Service	Port	Service
20, 21	FTP (cleartext)	389 / 636	LDAP / LDAPS
22	SSH / SCP / SFTP	443	HTTPS
23	Telnet (cleartext)	445	SMB / Microsoft-DS
25 / 587	SMTP / submission	514	Syslog
53	DNS (TCP and UDP)	993 / 995	IMAPS / POP3S
67, 68 / 69	DHCP / TFTP	1433	Microsoft SQL
80 / 8080	HTTP / HTTP alt	3306 / 5432	MySQL / PostgreSQL
88 / 135	Kerberos / MSRPC	3389	RDP
110 / 143	POP3 / IMAP4	5900	VNC
123 / 161	NTP / SNMP	137-139	NetBIOS

The full grouped reference — roughly 200 ports — is in the Unit 3 learning plan.

Red Flags on an External Scan

These ports are unremarkable inside a network and alarming outside one:

- **23, 21** — cleartext Telnet or FTP reachable from the internet. Credentials cross the wire in plain text.
- **139, 445** — SMB exposed externally. This is how a large share of ransomware gets its first foothold.
- **1433, 3306, 5432** — a database server that was never meant to leave its segment.
- **3389, 5900** — RDP or VNC facing the internet. Constantly brute-forced, constantly successful.
- **161** — SNMP, often still answering to the community string `public`.



SECURITY FOCUS

Confirm before you escalate, then escalate promptly. Both halves matter — a false alarm and a late warning cost you the same credibility.

Why it matters: The most interesting result is a well-known port answering with the wrong protocol. That is where tunneling hides.

The Four Tools

Tool	What it is for	Trade-off
Nmap	Discovery, port scanning, version and OS detection, NSE	Slowest, because it does the most
Masscan	Asynchronous SYN sweep across enormous ranges	Finds ports; does not fingerprint them
Nikto	Web server checks: dangerous files, stale software, defaults	Deliberately loud; makes no attempt to hide
Legion	GUI that orchestrates the others automatically	Great for orienting; hides what it ran

The professional pattern: Masscan across a wide range to find what answers, then Nmap with -sV against only the host:port pairs that came back.

Running Them in Practice

```
$ sudo nmap -sS -sV -T4 -oA mstclab www.mstclab.com
$ sudo masscan 192.168.1.0/24 --ports 0-6000 --rate 1000
$ nikto -h http://www.mstclab.com
```

- **Masscan's rate is the safety control** — the default is a deliberate 100 packets/sec and it can go far higher. Bound every run.
- **Masscan needs a port specification** — running it bare fails with "no ports were specified", then tells you exactly what to add. Read the hints.
- **Kali colors your command red until it resolves** — free typo detection before you press enter.
- **Budget UDP separately** — do not bolt it onto a TCP scan you expected to finish quickly.

LIVE DEMO

Run masscan with no ports to show the hint, then sudo !! after the permission error.

Online and Passive Tools

Browser-based services run the scan from their infrastructure instead of yours:

- **HackerTarget** — web versions of many Kali tools, with a free tier suitable for coursework.
- **Shodan** and **Censys** — searchable indexes of internet-facing devices and certificates. Passive from your side; the scanning already happened.
- **Cisco Talos** and **SANS ISC** — reputation data, plus reporting on what is being scanned right now.
- **GRC ShieldsUP!** — scans the public address you are connecting from. Point it only at yourself.
- **crt.sh** — certificate transparency search, which routinely reveals internal hostnames.



The trade-off

For: not attributable to you, and more capacity than your laptop.

Against: you have disclosed your target to a third party, and you cannot see anything behind the perimeter.

Some information can only be gathered internally.

LESSON 5

The Defensive View



What a Scan Looks Like to the Blue Team

MITRE ATT&CK T1046 — Network Service Discovery. Attackers scan for exactly the reasons you do.

- **Fan-out on one port** — one source touching many addresses on the same port. Almost nothing legitimate looks like this.
- **Fan-out on one host** — one source touching many ports on one destination.
- **High failure ratio** — normal clients connect to services that exist; a scanner generates RSTs and timeouts.
- **Half-open connections** — SYNs without a completing ACK, visible in firewall state tables.
- **Process-level indicators** — EDR seeing `nmap` or `masscan` execute on a workstation is not recon, it is a compromised host.

Detection Sources and Mitigations

Where the evidence lives

- Firewall and NetFlow logs — best single source for fan-out patterns
- IDS/IPS — Suricata and Zeek detect port scans out of the box
- Host logs — Windows Event Log and `/var/log/auth.log`
- Web server logs — Nikto leaves a trail of requests for paths that do not exist
- Honeypots — any connection at all is a high-confidence alert

What actually helps

- Network segmentation — the highest-impact control by a wide margin
- Reduce the attack surface — fewer listening services, fewer doors
- Default deny at the perimeter — filtered beats closed
- Rate limiting — slows enumeration and alerts as a side effect
- Alert on internal scanning specifically — external scanning is background noise

The Finding You Cannot Remediate

Not every exposure has a fix — and a report that pretends otherwise is worth less, not more.



SECURITY FOCUS

An external scan finds 3389/tcp open. The business confirms a vendor genuinely requires RDP for a supported application, with no alternative path. You cannot close that port — so convert it into a control requirement instead: restrict source addresses to the vendor's published ranges, require MFA at the gateway, alert on any authentication from outside those ranges, and set a review date.

Why it matters: An exposure that is accepted, documented, and instrumented is a fundamentally different risk from one nobody knew about.

Your Scan Output Is Sensitive

The information you gather is valuable to exactly the people you are protecting the target from.

- **Share only with those designated to know** — the system owner and the people they name. Not classmates, not social media, not a public repo.
- **Have no surprises at the end** — serious issues get flagged early. A critical finding revealed for the first time in a final presentation is a failure of the engagement.
- **But verify before you sound the alarm** — have someone confirm a major finding first. Crying wolf costs credibility you will need later.
- **Mark and store deliberately** — label the classification on the document, and keep raw output somewhere with access control.



For this course

Scan results produced in this class are **TLP:AMBER** by default.

Discuss them with people in the room or with instructor permission, and nowhere else.

Traffic Light Protocol 2.0

The standard for telling a recipient how far they may pass information along. Maintained by FIRST.

Marking	How far it may travel	Typical use
TLP:RED	Named recipients only — no further	Said in one meeting, nowhere else
TLP:AMBER+STRICT	Your organization only, need-to-know	New in version 2.0
TLP:AMBER	Organization and its clients, need-to-know	Most engagement findings
TLP:GREEN	Community wide, but never posted publicly	Sector threat sharing
TLP:CLEAR	Unlimited distribution	Renamed from TLP:WHITE in 2.0

Markings carry no space and are always uppercase. Unsure what applies? Treat it one level more restrictive and ask the originator.

Traffic Light Protocol 2.0



TLP: RED

Not For Disclosure

This information cannot be disseminated to third parties unless the sender permits it

Only participating groups can have access to it.

TLP: AMBER



Limited Disclosure

This information can be shared with participants of an organization or some members of a community

Additional restrictions can be made.



TLP: GREEN

Community-Wide Disclosure

This information can be shared with everyone in a particular community

However, it cannot be published publicly on the Internet.

TLP: WHITE



Unlimited Disclosure

This information can be shared publicly with everyone

However, the laws of Copyright still need to be applied

Hands-On Lab



Authorized targets only · results are TLP:AMBER

- **Lab 1 — Metadata:** recover the location from the provided image, compare original against the copy, then strip and verify.
- **Lab 2 — Two methods:** scan `www.mstclab.com` with a Kali tool and an online tool. List every open port and label what it is open for.
- **Lab 2, part two:** find a partner who used a different tool. Compare results, ease of use, and depth of detail.
- **Lab 3 — Live target:** scan a box on **Hack The Box** or **TryHackMe**. Full TCP port scan, then `-sV` on what answered.
- **Deliverable:** a port inventory table — port, protocol, state, service, version, and why each is interesting.

Graded on the reasoning behind your flags, not just the output you captured.

Homework



- **Unit 3 Lab 1** — go scan a box on **Hack The Box** or **TryHackMe**. Either platform counts; use whichever account you already have.
- **Unit 3 Assignment 1** — a short write-up comparing Nmap, Masscan, Nikto, and Legion.
- Record the exact commands you ran, and compare speed, depth of information, ease of use, and how noisy each tool is.
- Recommend which tool fits which situation, with reasoning rather than preference.
- Describe what evidence each tool would leave in a defender's logs — and apply the correct TLP marking to the finished document.

Start memorizing the common ports now. We will open next class with them.

Key Takeaways



You cannot scan what you cannot navigate — get comfortable in the shell first.



Copying and renaming a file sanitizes nothing. Metadata survives almost everything.



Every TCP scan type is a decision about how much of the handshake to finish.



Port states matter: open, closed, and filtered describe three different situations.



"Stealthy" means invisible to the application log, not to the network.



Your results are TLP:AMBER. How you handle them is graded alongside how you got them.

MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Questions?

Unit 3 · Network Scanning

